[별표 3]

<개정 2022.7.7., 2026.8.13.>

기술적·물리적·관리적 보안대책 마련 기준(제20조 관련)

Ⅰ. 목 적

이 기준은 영 제16조제1항에서 정하는 신용정보의 기술적·물리적·관리적 보안대책과 관련된 구체적인 기준을 정함을 목적으로 한다.

Ⅱ. 기술적·물리적 보안대책

1. 접근통제

① 신용정보회사등은 개인신용정보를 처리할 수 있도록 체계적으로 구성한 전산시스템(이하 "개인신용정보처리시스템"이라 한다)에 대한 접근권한을 서비스제공을 위하여 필요한 최소한의 인원에게만 부여한다.

② 신용정보회사등은 전보 또는 퇴직 등 인사이동이 발생하여 신용정보회사등의 지휘·감독을 받아 개인신용정보를 처리하는 업무를 담당하는 자(이하 "개인신용정보취급자"라 한다)가 변경되었을 경우 지체 없이 개인신용정보처리시스템의 접근권한을 변경 또는 말소한다.

③ 신용정보회사등은 제1항 및 제2항에 따른 권한 부여, 변경 또는 말소에 대한 내역을 기록하고, 그 기록을 최소 3년간 보관한다.

④ 신용정보회사등은 개인신용정보처리시스템에 침입차단시스템과 침입탐지시스템을 설치하여 보호한다.

⑤ 신용정보회사등은 개인신용정보주체 및 개인신용정보취급자가 생일, 주민등록번호, 전화번호 등 추측하기 쉬운 숫자를 비밀번호로 이용하지 않도록 비밀번호 작성규칙을 수립하고 이행한다.

⑥ 신용정보회사등은 취급 중인 개인신용정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 열람 권한이 없는 자에게 공개되지 않도록 개인신용정보처리시스템 및 개인신용정보취급자의 PC를 설정한다.

⑦ 신용정보회사등은 제휴, 위탁 또는 외부주문에 의한 개인신용정보처리시스템, 신용평가모형 또는 위험관리모형 개발업무에 사용되는 업무장소 및 전산설비는 내부 업무용과 분리하여 설치·운영한다.

⑧ 신용정보회사등은 업무목적을 위하여 불가피한 경우에만 외부사용자에게 개인신용정보처리시스템에 대한 최소한의 접근권한을 부여하고, 권한 부여에 관한 기록을 3년 이상 보관하는 등 적절한 통제시스템을 갖추어야 한다.

2. 접속기록의 위·변조방지

① 신용정보회사등은 개인신용정보취급자가 개인신용정보처리시스템에 접속하여 개인신용

정보를 처리한 경우에는 처리일시, 처리내역 등 접속기록을 저장하고 이를 월 1회 이상 정기적으로 확인·감독한다.

② 신용정보회사등은 개인신용정보처리시스템의 접속기록을 1년 이상 저장하고, 위·변조되지 않도록 별도 저장장치에 백업 보관한다.

3. 개인신용정보의 암호화

① 신용정보회사등은 비밀번호, 생체인식정보 등 본인임을 인증하는 정보는 암호화하여 저장하며, 이는 조회할 수 없도록 하여야 한다. 다만, 조회가 불가피하다고 인정되는 경우에는 그 조회사유·내용 등을 기록·관리하여야 한다.

② 신용정보회사등은 정보통신망을 통해 개인신용정보 및 인증정보를 송·수신할 때에는 보안서버 구축 등의 조치를 통해 이를 암호화해야 한다. 보안서버는 다음 각 호의 어느 하나의 기능을 갖추어야 한다.

1. 웹서버에 SSL(Secure Socket Layer) 인증서를 설치하여 개인신용정보를 암호화하여 송·수신하는 기능
2. 웹서버에 암호화 응용프로그램을 설치하여 개인신용정보를 암호화하여 송·수신하는 기능

③ 신용정보회사등은 개인신용정보를 PC에 저장할 때에는 이를 암호화해야 한다.

④ 신용정보회사등은 다음 각 호의 기준에 따라 개인식별정보의 암호화 등의 조치를 취하여야 한다.

1. 정보통신망을 통하여 송수신하거나 보조저장매체를 통하여 전달하는 경우에는 암호화하여야 한다.
2. 인터넷 구간 및 인터넷 구간과 내부망의 중간 지점(DMZ : Demilitarized Zone) 에 저장할 때에는 암호화하여야 한다.
3. 신용정보회사등이 내부망에 개인식별정보를 저장하는 경우에는 암호화하여야 한다. 다만, 영 제2조제2항 각 호의 정보 중 주민등록번호 외의 정보를 저장하는 경우에는 다음 각 목의 기준에 따라 암호화의 적용여부 및 적용범위를 정하여 시행할 수 있다.
   가. 「개인정보 보호법」 제33조에 따른 개인정보 영향평가의 대상이 되는 공공기관의 경우에는 해당 개인정보 영향평가의 결과
   나. 그 밖의 신용정보회사등의 경우에는 개인신용정보처리시스템에 적용되고 있는 개인신용정보 보호를 위한 수단과 개인신용정보 유출시 신용정보주체의 권익을 해할 가능성 및 그 위험의 정도를 분석한 결과
4. 업무용 컴퓨터 또는 모바일 기기에 저장하여 관리하는 경우에는 상용 암호화 소프트웨어 또는 안전한 알고리즘을 사용하여 암호화하여야 한다.

⑤ 신용정보집중기관과 개인신용평가회사, 개인사업자신용평가회사, 기업신용조회회사(기업정보조회업무만 하는 기업신용조회회사는 제외한다)가 서로 개인식별번호를 제공하는 경우에는 상용 암호화 소프트웨어 또는 안전한 알고리즘을 사용하여 암호화하여야 한다.

⑥ 신용정보회사등이 개인신용정보의 처리를 위탁하는 경우 개인식별번호를 암호화하여 수탁자에게 제공하여야 한다.

4. 컴퓨터바이러스 방지

① 신용정보회사등은 개인신용정보처리시스템 및 개인신용정보취급자가 개인신용정보 처리에 이용하는 정보처리기기에 컴퓨터바이러스, 스파이웨어 등 악성프로그램의 침투 여부를 항시 점검·치료할 수 있도록 백신소프트웨어를 설치한다.

② 제1항에 따른 백신 소프트웨어는 월 1회 이상 주기적으로 갱신·점검하고, 바이러스 경보가 발령된 경우 및 백신 소프트웨어 제작 업체에서 업데이트 공지를 한 경우에는 즉시 최신 소프트웨어로 갱신·점검한다.

5. 출력·복사시 보호조치

① 신용정보회사등은 개인신용정보처리시스템에서 개인신용정보의 출력시(인쇄, 화면표시, 파일생성 등) 용도를 특정하여야 하며, 용도에 따라 출력 항목을 최소화 한다.

② 신용정보회사등은 개인신용정보를 조회(활용)하는 경우 조회자의 신원, 조회일시, 대상정보, 목적, 용도 등의 기록을 관리하여야 하며, 개인신용정보취급자가 개인신용정보를 보조저장매체에 저장하거나 이메일 등의 방법으로 외부에 전송하는 경우에는 관리책임자의 사전 승인을 받아야 한다.

③ 개인신용정보취급자는 제1항 및 제2항의 준수에 필요한 내부시스템을 구축하여야 하며 사전 승인시 승인신청자에게 관련 법령을 준수하여야 한다는 사실을 주지시켜야 한다.

Ⅲ. 관리적 보안대책

1. 신용정보관리·보호인

① 신용정보관리·보호인은 다음 각 호의 업무를 담당한다.

1. 개인신용정보의 경우
   가. 「개인정보 보호법」 제31조제4항제1호부터 제7호까지의 업무
   나. 임직원 및 전속 모집인 등의 신용정보보호 관련 법령 및 규정 준수 여부 점검
2. 기업신용정보의 경우
   가. 신용정보의 수집·보유·제공·삭제 등 관리 및 보호 계획의 수립 및 시행
   나. 신용정보의 수집·보유·제공·삭제 등 관리 및 보호 실태와 관행에 대한 정기적인 조사 및 개선
   다. 신용정보 열람 및 정정청구 등 신용정보주체의 권리행사 및 피해구제
   라. 신용정보 유출 등을 방지하기 위한 내부통제시스템의 구축 및 운영

마. 임직원 및 전속 모집인 등에 대한 신용정보보호 교육계획의 수립 및 시행

바. 임직원 및 전속 모집인 등의 신용정보보호 관련 법령 및 규정 준수 여부 점검

② 신용정보관리·보호인은 제1항의 업무처리에 따른 기록을 3년간 보존하며, 점검결과를 경영진에 보고하고 업무처리절차에 적절히 반영하여야 한다.

2. 개인신용정보의 조회권한 구분

① 신용정보관리·보호인은 개인신용정보 조회 권한이 직급별·업무별로 차등 부여되도록 하여야 한다.

② 신용정보회사등은 개인신용정보의 조회기록에 대하여는 다음 각 호에 따라 주기적으로 그 적정성 여부를 점검하여야 하며, 점검결과를 업무에 반영하여야 한다.

1. 개인신용정보취급자의 개인신용정보 취급상황을 확인할 수 있는 수단 및 이의 점검·감사체제 정비
2. 개인신용정보 이상 과다 조회 부서 및 직원 등에 대해 수시 점검 실시

가. 조회 권한을 초과하여 고객 정보 조회를 일정횟수 이상 시도한 직원에 대한 통제장치 마련

나. 영업점 및 신용정보 관리부서의 개인신용정보 조회 건수에 대해 정기적으로 점검하고 조회건수가 평소보다 급증한 부서 및 직원들을 샘플링하여 점검 실시

③ 신용정보 관리·보호인은 개인신용정보취급자가 입력하는 조회사유의 정확성 등 신용조회기록의 정확성을 점검하여야 한다.

3. 개인신용정보의 이용제한 등

① 신용정보회사등은 신용평가모형 또는 위험관리모형 개발 위탁시 개인신용정보를 제공할 수 없다. 다만, 모형 개발을 위하여 불가피한 경우에는 실제 개인신용정보를 변환하여 제공한 후 모형 개발 완료 즉시 삭제하여야 한다.

② 개인신용평가회사, 개인사업자신용평가회사, 기업신용조회회사가 신용평가모형 및 위험관리모형을 개발하는 경우, 개인신용정보를 사용하지 않으면 모형 개발 또는 검증 등이 불가능하여 불가피하게 필요한 경우 외에는 실제 개인신용정보를 사용하여서는 아니 된다.

4. 제재기준 마련

신용정보회사등은 개인신용정보 오·남용에 대한 자체 제재기준을 마련하여야 한다.